

Cybersécurité opérationnelle

Au coeur de la détection, la supervision et l'orchestration de la sécurité en environnement réel

Contexte

Dans un paysage de menaces en constante évolution, les organisations font face à des cyberattaques de plus en plus sophistiquées et fréquentes. La cybersécurité opérationnelle est devenue un pilier essentiel de toute stratégie de défense efficace. Au-delà de la simple mise en place de solutions techniques, les entreprises doivent aujourd'hui développer des capacités avancées de détection, d'analyse et de réponse aux incidents pour protéger leurs infrastructures et leurs données critiques.

Les centres opérationnels de sécurité (SOC) modernes s'appuient sur une combinaison d'outils, de processus et de compétences humaines pour assurer une surveillance continue, détecter rapidement les menaces et y répondre efficacement. Face à l'augmentation du volume d'alertes et à la complexité des attaques, l'automatisation et l'orchestration des opérations de sécurité sont devenues indispensables pour améliorer l'efficacité des équipes et réduire le temps de réponse aux incidents.

C'est dans ce contexte que nous vous proposons le **Défi de Cybersécurité Opérationnelle**, une immersion dans le monde des SOC modernes où vous



mettrez en pratique les techniques et outils utilisés par les professionnels du domaine pour détecter, analyser et répondre aux menaces de cybersécurité.

Introduction du sujet

Ce projet consiste à **mettre en place** et opérer un **centre opérationnel de sécurité (SOC)** complet pour détecter, analyser et répondre à des incidents de sécurité dans un environnement simulé mais réaliste. Vous serez confrontés à différents scénarios d'attaques et devrez utiliser les outils et méthodologies de l'état de l'art pour assurer la protection de l'infrastructure.

Pour ce projet, vous devrez :

1. **Déployer et configurer** une infrastructure de détection et de réponse
2. **Mettre en place** une solution de gestion centralisée des logs et des alertes
3. **Développer** des règles de détection pertinentes
4. **Analyser** les alertes générées et mener des investigations
5. **Automatiser** les processus de réponse aux incidents
6. **Documenter** vos actions et découvertes dans un rapport professionnel

Note : En amont de la mise en place, bien identifier dès le départ les **objectifs**, les **technologies à collecter** et les **scénarios de détection en fonction des risques**.

Vous travaillerez avec des outils professionnels de cybersécurité opérationnelle et des datasets réalistes pour simuler un environnement d'entreprise sous attaque.

Scénarios opérationnels à traiter



Scénario 1 : Détection et réponse aux menaces avancées

Une entreprise fictive, TechnoVision, n'a pas encore **déployé de solution EDR (Endpoint Detection and Response)** ni les processus d'analyse et de réponse associés. **Des comportements suspects ont été détectés** sur plusieurs postes de travail, notamment des connexions à des domaines inconnus, des exécutions de scripts PowerShell inhabituelles et des modifications de registre suspectes.

Votre mission:

1. Déployer et configurer Wazuh :

- Installer Wazuh Manager sur une machine virtuelle Linux (Ubuntu 22.04)
- Déployer les agents Wazuh sur au moins 3 machines virtuelles (2 Windows, 1 Linux)
- Configurer la collecte des logs Windows (Security, System, Application)
- Activer les modules de détection FIM (File Integrity Monitoring) et SCA (Security Configuration Assessment)

2. Analyser les alertes générées :

- Identifier les alertes liées à des comportements suspects
- Classifier les alertes par niveau de criticité
- Corréler les alertes pour identifier des chaînes d'attaque potentielles
- Utiliser le framework MITRE ATT&CK pour catégoriser les techniques d'attaque observées

3. Investiguer les incidents détectés :

- Analyser en profondeur au moins 3 incidents de sécurité de catégories distinctes (ex: Simple comme une exécution d'une commande, moyenne - persistance via script, complexe -kill chain complète du phishing à l'exfiltration)
- Reconstruire la chronologie des événements pour chaque incident



- Identifier les indicateurs de compromission (IoC)
 - Déterminer l'étendue de la compromission
4. Mettre en place des mesures de remédiation :
- Développer des procédures d'isolation des postes compromis
 - Créer des scripts de nettoyage pour les malwares identifiés
 - Implémenter des règles de détection personnalisées pour prévenir des attaques similaires
 - Proposer des mesures de durcissement des systèmes
5. Développer des playbooks de réponse automatisée :
- Créer au moins 2 playbooks de réponse pour les menaces identifiées
 - Automatiser l'isolation des postes compromis
 - Mettre en place des actions de remédiation automatiques pour les menaces connues
 - Tester l'efficacité des playbooks sur des scénarios d'attaque simulés

Ressource fournie :

- Environnement virtualisé "Enterprise Network Simulation" avec machines Windows et Linux pré-configurées
- Dataset "APT Simulation" contenant des traces d'activités malveillantes simulant les techniques APT29 et APT28
- Documentation complète sur l'installation et la configuration de Wazuh
- Accès à une instance cloud de Wazuh Manager pour les étudiants ne disposant pas des ressources nécessaires

Livrables attendus

- **Dossier d'architecture détaillée (DAT)** de la solution EDR déployée formalisant l'architecture, les flux, les composants et les exigences techniques de la solution (en entreprise il est validé par le RSSI)
- Documentation des configurations réalisées
- Analyse détaillée des incidents détectés



- Playbooks de réponse développés (format YAML ou JSON)
- Rapport d'investigation pour chaque incident majeur



Scénario 2 : Centralisation et corrélation des logs de sécurité

TechnoVision souhaite **améliorer sa capacité de détection** en **centralisant et en corrélant les logs** provenant de différentes sources (systèmes d'exploitation, applications, équipements réseau). L'entreprise fait face à un volume important de logs (plus de 10 Go par jour) et a besoin d'une solution permettant d'identifier rapidement les incidents de sécurité parmi le bruit de fond.

Votre mission:

1. Déployer et configurer Elastic Stack :

- Installer Elasticsearch, Logstash, Kibana et Filebeat
- Configurer la rétention des données (7 jours minimum)
- Mettre en place une architecture distribuée avec au moins 2 nœuds Elasticsearch
- Sécuriser l'accès à la plateforme (authentification, TLS)

2. Intégrer différentes sources de logs :

- Configurer la collecte des logs Windows via Winlogbeat
- Intégrer les logs Linux via Filebeat
- Collecter les logs des équipements réseau (Cisco, Fortinet ou pfSense)
- Intégrer les logs d'applications web (Apache, Nginx)
- Configurer des pipelines Logstash pour normaliser les formats de logs

3. Développer des règles de corrélation :

- Créer au moins 10 règles de détection Elastic SIEM
- Implémenter des règles basées sur le framework Sigma
- Développer des détections pour les techniques MITRE ATT&CK courantes
- Mettre en place des règles de corrélation multi-sources



4. Créer des tableaux de bord de visualisation :
 - Développer un dashboard de supervision générale
 - Créer des visualisations spécifiques pour les différents types d'alertes
 - Mettre en place des timelines pour l'analyse d'incidents
 - Développer des rapports automatisés (quotidiens, hebdomadaires) et un **tableau de bord de la qualité des collectes**
5. Mettre en place un système d'alerte efficace :
 - Configurer des alertes par email pour les incidents critiques
 - Intégrer les alertes avec un système de messagerie (Slack, Teams)
 - Implémenter un système de déduplication des alertes
 - Mettre en place un mécanisme de priorisation des alertes
6. Analyser des incidents complexes :
 - Investiguer au moins 2 incidents nécessitant la corrélation de plusieurs sources
 - Reconstruire la chronologie complète des attaques
 - Identifier les faux positifs et améliorer les règles de détection
 - Documenter le processus d'investigation

Ressource fournie :

- Solution SIEM Elastic Stack (Elasticsearch, Logstash, Kibana)
- Dataset "Multi-source Security Logs" contenant des logs de différentes sources
- Templates de règles de corrélation et de tableaux de bord
- Documentation sur l'analyse de logs et la détection d'anomalies
- Images Docker préconfigurées pour faciliter le déploiement

Livrables attendus

- Architecture détaillée de la solution SIEM (DAT)



- Plan de surveillance (PDS) qui décrit les modalités de contrôle et de suivi de la sécurité
- Documentation des configurations et des pipelines Logstash
- Tableaux de bord et visualisations créés (exports JSON)
- Rapports d'analyse des incidents complexes

Scénario 3 : Automatisation et orchestration de la sécurité

Face à l'augmentation du volume d'alertes (plus de 1000 par jour), TechnoVision souhaite automatiser certaines tâches d'analyse et de réponse pour améliorer l'efficacité de son équipe de sécurité composée de seulement 3 analystes. L'objectif est de réduire le temps moyen de détection (MTTD) et le temps moyen de réponse (MTTR) aux incidents.

Votre mission:

1. Déployer et configurer TheHive et Cortex :
 - Installer TheHive pour la gestion des incidents
 - Déployer Cortex pour l'analyse automatisée des IoCs
 - Configurer les analyseurs Cortex (VirusTotal, MISP, URLhaus, etc.)
 - Mettre en place un système de ticketing pour le suivi des incidents
2. Intégrer le SOAR avec les solutions existantes :
 - Configurer l'intégration entre Wazuh et TheHive
 - Mettre en place l'intégration entre Elastic SIEM et TheHive
 - Développer des connecteurs personnalisés si nécessaire (Python)
 - Valider le flux d'informations entre les différentes solutions
3. Développer des workflows d'automatisation :
 - Automatiser la création de cas dans TheHive à partir des alertes
 - Mettre en place l'enrichissement automatique des IoCs
 - Développer des workflows pour la classification des alertes



→ Automatiser la génération de rapports d'incidents

4. Créer des playbooks de réponse :

→ Développer au moins 5 playbooks pour différents types d'incidents:

- ◆ Détection de malware
- ◆ Compromission de compte
- ◆ Mouvement latéral
- ◆ Exfiltration de données
- ◆ Attaque par déni de service

→ Implémenter ces playbooks dans TheHive/Cortex

- ◆ Tester les playbooks sur des scénarios d'attaque simulés

Note :

Ces playbooks peuvent être par exemple:

- Playbook isolation d'une machine
- Playbook de communication vers un Slack par exemple pour demander une validation à une DSI ou une entité métier
- Playbook de recherche d'information (ex : infos d'un SI RH)

5. Mettre en place un système de ticketing :

- Configurer les templates de tickets dans TheHive
- Définir les workflows de traitement des incidents
- Mettre en place un système d'escalade pour les incidents critiques
- Intégrer le système de ticketing avec un outil de communication (Slack, Teams)

6. Évaluer l'efficacité des automatisations :

- Mesurer le MTTD et MTTR avant et après automatisation
- Analyser le taux de faux positifs
- Évaluer la charge de travail des analystes
- Proposer des améliorations basées sur les métriques collectées

Ressource fournie :

- Plateforme SOAR TheHive et Cortex



- Documentation sur l'intégration avec Wazuh et Elastic Stack
- Exemples de playbooks pour différents types d'incidents
- Dataset "Security Incidents" pour tester les automatisations
- Scripts Python d'intégration et d'automatisation

Livrables attendus

- Architecture détaillée de la solution SOAR
- Documentation des intégrations réalisées
- Collection de playbooks développés
- Rapport d'évaluation de l'efficacité des automatisations
- Recommandations pour l'amélioration continue du SOC

Méthodologie et outils

Pour réaliser ces investigations, vous devrez suivre une méthodologie opérationnelle rigoureuse:

1. Préparation de l'environnement :

Déployer les outils nécessaires (EDR, SIEM, SOAR)
Configurer les intégrations entre les différents outils
Valider le bon fonctionnement de l'infrastructure
Documenter l'architecture mise en place

2. Détection et analyse :

Configurer les sources de données et les règles de détection
Analyser les alertes générées
Mener des investigations approfondies
Identifier les faux positifs et les améliorer
Utiliser le framework MITRE ATT&CK pour catégoriser les menaces

3. Réponse et automatisation :



Développer des procédures de réponse aux incidents
Automatiser les tâches répétitives
Mettre en place des mesures de remédiation
Évaluer l'efficacité des réponses
Améliorer continuellement les processus

4. **Documentation et reporting :**

Documenter l'architecture mise en place
Rédiger des procédures opérationnelles
Produire des rapports d'incidents
Présenter les résultats et recommandations
Maintenir un journal des actions réalisées

Outils :

EDR (Endpoint Detection and Response) :

- Wazuh (open source) :

- Fonctionnalités: FIM, SCA, détection de malware, réponse active
- Avantages: Gratuit, facile à déployer, communauté active
- Documentation: <https://documentation.wazuh.com/>
- Alternatives commerciales: CrowdStrike Falcon, SentinelOne, Microsoft Defender for Endpoint

SIEM (Security Information and Event Management) :

- Elastic Stack (Elasticsearch, Logstash, Kibana) :

- Fonctionnalités: Collecte de logs, analyse, visualisation, détection
- Avantages: Flexible, scalable, nombreux intégrateurs
- Documentation: <https://www.elastic.co/guide/index.html>
- Alternatives commerciales: Splunk, IBM QRadar, Microsoft Sentinel

SOAR (Security Orchestration, Automation and Response) :

- TheHive + Cortex :

- Fonctionnalités: Gestion des incidents, automatisation, analyse d'loCs



- Avantages: Open source, API riche, extensible
- Documentation: <https://docs.thehive-project.org/>
- Alternatives commerciales: Palo Alto XSOAR, Splunk SOAR, IBM SOAR

Outils complémentaires :

- Virtualisation : VirtualBox, VMware, Docker
- Scripting : Python pour l'automatisation et l'intégration
- Threat Intelligence : MISP, AlienVault OTX, VirusTotal
- Analyse de logs : Sigma rules, ELK Stack
- Visualisation : Kibana, Grafana

Pour aller plus loin

Pour les étudiants souhaitant approfondir leurs compétences, vous pouvez mettre en place les éléments suivants :

Intégration de Threat Intelligence :

- Déployer une instance MISP (Malware Information Sharing Platform)
- Intégrer des flux de threat intelligence dans votre SIEM
- Développer des mécanismes de détection basés sur les IoCs
- Mettre en place un processus de partage d'informations

Détection avancée avec Machine Learning :

- Implémenter des détections basées sur le machine learning dans Elastic
- Développer des modèles de détection d'anomalies
- Créer des systèmes de scoring de risque automatisés
- Évaluer l'efficacité des détections ML vs règles traditionnelles

Déception et Honeypots :

- Déployer des honeypots dans l'environnement (HoneydV6, T-Pot)
- Intégrer les alertes des honeypots dans le SIEM
- Analyser les techniques utilisées par les attaquants



- Développer des détections basées sur les attaques observées

Dashboard de supervision temps réel :

- Créer un dashboard de supervision SOC temps réel
- Développer des métriques de performance du SOC
- Mettre en place des visualisations avancées
- Intégrer des données de threat intelligence

Développement de connecteurs personnalisés :

- Créer des connecteurs pour des outils spécifiques
- Développer des intégrations avec des API externes
- Automatiser l'enrichissement des alertes
- Mettre en place des workflows complexes

Tests d'intrusion pour validation :

- Réaliser des tests d'intrusion pour valider les détections
- Utiliser des frameworks comme Atomic Red Team
- Simuler des techniques MITRE ATT&CK
- Mesurer l'efficacité des détections et réponses

Rendu

Comme à votre habitude, votre travail devra être sauvegardé dans un repository sur GitHub appelé **cybersecurity_operations_challenge**. Pour chaque scénario, vous fournirez:

1. Un rapport détaillant l'architecture mise en place, les configurations réalisées et les résultats obtenus
2. Les scripts et configurations développés (règles de détection, playbooks, etc.)
3. Les tableaux de bord et visualisations créés
4. Une démonstration vidéo du fonctionnement de votre SOC



5. Une présentation des incidents détectés et des réponses apportées

Votre travail sera évalué en présentation avec un support à l'équipe pédagogique.



Compétences techniques

- Configuration et administration d'outils EDR
- Déploiement et configuration de solutions SIEM
- Développement de règles de détection et de corrélation
- Analyse de logs et d'alertes de sécurité
- Automatisation et orchestration des opérations de sécurité
- Scripting Python pour l'intégration et l'automatisation
- Gestion d'incidents de sécurité
- Analyse de malware basique
- Forensique numérique
- Threat hunting

Compétences visées par la certification professionnelle

- Analyse et traitement des alertes (EDR, XDR, MDR)
- Gestion des logs, corrélation et détection centralisée (SIEM)
- Automatisation, intégration et réponse rapide (SOAR)
- Mise en place de procédures opérationnelles de sécurité
- Documentation et reporting d'incidents de sécurité
- Stratégie d'un SOC et gestion
- Threat Intelligence
- Réponse aux incidents
- Communication technique et non-technique

Base de connaissances

- [Guide SANS d'investigation numérique](#)



- [Guide SANS SOC Survey](#)
- [Documentation Wazuh](#)
- [Documentation Elastic Security](#)
- [Documentation TheHive Project](#)
- [MITRE ATT&CK Framework](#)
- [Sigma Rules Repository](#)
- [SOC Automation Best Practices](#)
- [Incident Response Playbooks](#)
- [SANS Incident Handler's Handbook](#)
- [NIST Computer Security Incident Handling Guide](#)
- [Awesome-SOC](#)
- [SOC-CMM: Security Operations Center Capability Maturity Model](#)
- [Detection Engineering: The Definitive Guide](#)